Layer2Meetup@SF Meeting Report

- BGIN is a multi-stakeholder discussion body / distributed think tank.

Cybersecurity Information-Sharing

bg in

blockchain
governance
initiative
network

The Global Network for Blockchain Stakeholders™

© 2023 BGIN (Blockchain Governance Initiative Network) is registered as BN Association, a Japanese general association with its principal place of business at Shiba Building, 704, 4-7-6, Shiba, Minato-ku, Tokyo. All rights reserved.

The know-how described in this document was made available from contributions from various sources, including members of the BGIN and others. Although the BGIN has taken steps to help ensure that the know how is available for distribution, it takes no position regarding the validity or scope of any intellectual property or other rights that might be claimed to pertain to the implementation or use of the know how described in this document or the extent to which any license under such rights might or might not be available; neither does it represent that it has made any independent effort to identify any such rights. BGIN and the contributors to this document make no (and hereby expressly disclaim any) warranties (express, implied, or otherwise), including implied warranties of merchantability, non-infringement, fitness for a particular purpose, or title, related to this document, and the entire risk as to implementing this document is assumed by the implementer. The BGIN Intellectual Property Rights policy requires contributors to offer a patent promise not to assert certain patent claims against other contributors and against implementers. BGIN invites any interested party to bring to its attention any copyrights, patents, patent applications, or other proprietary rights that may cover technology that may be required to practice this document.

Layer2 Meetup@Sydney

Keynote Session Report: Cybersecurity Information-Sharing

Date: Wednesday, October 15th, 2024

Location: San Francisco, US

Duration: Approx. 90 minutes

Summary

General Overview of Cybersecurity Information Sharing:

- Vulnerabilities are typically discovered and reported by researchers and security professionals to vendors.
- Vendors fix vulnerabilities, create security patches, and include information in the **CVE list** (managed by MITRE, a nonprofit organization).
- Researchers may also report vulnerabilities directly to the **CVE program**, which prompts vendors to address them.
- MITRE assigns **CVE IDs** to reported vulnerabilities and manages their automation.
- The **National Vulnerability Database (NVD)**, managed by NIST, standardizes and analyzes CVE data.
- **ISACs (Information Sharing and Analysis Centers)** analyze industry-specific vulnerabilities and share best practices.

Challenges in the Crypto Industry:

- Responsible disclosure practices are underdeveloped in the crypto industry.
- Few crypto-related vulnerabilities are listed in the CVE, and it's unclear if MITRE will manage them extensively.
- **Crypto-ISAC** was established to handle blockchain-specific vulnerabilities but is limited in scope.
- The crypto industry faces a lack of talent and education in cybersecurity.
- **Product security** in crypto is distinct and requires unique approaches compared to other industries.
- There is no standardized data format or taxonomy for crypto threat intelligence and vulnerabilities.

Role of CCSS (Cryptocurrency Security Standard):

- CCSS began as a key management standard for Layer 1 technologies like custody and exchanges.
- **Version 8.2** adds 30% more requirements, addressing:
    - Risk governance, service provider management, wallet monitoring.

    - Smart contract audit requirements for all versions.
- CCSS aims to align with new technologies like **MPC** and zero-knowledge proofs by adopting broader terms like "key material."
- Unlike ISO 27001, CCSS focuses specifically on blockchain's unique challenges.

Gaps and Opportunities for Improvement:

- Need for simpler certification processes tailored to crypto startups (e.g., adapting ISO 27001 or NIST standards).
- CCSS offers three certification levels, enabling startups to adopt essential controls without heavy requirements.
- Developing **protection profiles** and **security targets** could be a starting point for crypto-specific standards.
- Formal verification and automated benchmarking tools for smart contracts are critical for reducing audit costs and enhancing security.

Collaboration and Education:

- BGIN could focus on creating educational content and standards for crypto cybersecurity.
- Engaging regulators and policymakers can help establish "big stick" mechanisms, similar to PCI DSS for credit card security.
- Increased awareness among leadership on cybersecurity liabilities is essential for driving investments in qualified professionals.

Other Standardization Bodies:

- The **Blockchain Security Standards Council** is membership-only and focuses on Web3 security standards.
- ISO's **TC307** works on blockchain and DLT standards but lacks cryptocurrency-specific focus.
- Collaboration with these organizations is crucial to address gaps in crypto cybersecurity.

Anonymized Transcript

So this is an overview of how cybersecurity information sharing alignment works in general in any industry.

For example, if there is a vulnerability in a vendor's product, researchers and security professionals discover and report vulnerabilities of the product directly to vendors. When vendors receive information about vulnerabilities, they fix the vulnerabilities and create a security patch. They also include the vulnerability information in the CVE list, the common vulnerabilities and exposures program list, managed by MITRE, a nonprofit organization based in Washington, D.C.

Researchers and security professionals sometimes directly report vulnerabilities to the CVE program. The CVE program requests vendors to create security patches and deal with these vulnerabilities. This is how responsible disclosure practices work in general across industries.

MITRE's responsibility is to apply CVE IDs to all vulnerabilities discovered and reported by researchers and security professionals. MITRE also manages the automation of vulnerabilities in the list. Once vulnerability information is added to the CVE list, it undergoes standardization with additional analysis in the National Vulnerability Database, which is managed by NIST.

These standardized databases are analyzed by industry-specific ISACs, which are Information Sharing and Analysis Centers. Each industry has its own ISAC. For example, the financial industry has FS-ISAC. Other industries also have ISACs, as the vulnerabilities in the national database are not industry-specific. ISACs analyze vulnerabilities and share sector-specific threat information and best practices with vendors, distributing relevant information to help vendors address vulnerabilities and threats.

This is how cybersecurity information sharing alignment works in the U.S. The question arises: can this alignment work in the crypto industry?

Responsible disclosure practices do not seem to work in the crypto industry as of now. While there are Web3 cybersecurity firms and smart contract auditors that make contracts with vendors and report vulnerabilities, there are no universally implemented practices across the crypto industry. Vulnerabilities in the crypto industry differ from traditional industries, and the format for vulnerability information may need to be specific to the crypto space.

Although some crypto-related vulnerabilities have been added to the CVE list, the number is very limited. It's unclear whether MITRE will manage vulnerability information for the crypto and blockchain sectors.

Crypto-ISAC was recently established in the U.S. and is responsible for sharing threat intelligence and vulnerability information specific to the crypto and blockchain industries. However, Crypto-ISAC is just one part of the larger cybersecurity information sharing framework. It cannot address all the challenges in the crypto industry.

We need to consider the role of Crypto-ISAC within this alignment and identify the missing pieces that need to be addressed, even after its establishment. For example, there is a significant lack of talent and education in the crypto cybersecurity field. While Web2 industries have many cybersecurity experts, the crypto industry struggles with a limited number of qualified professionals. Learning from other industries that have successfully increased the number of experts could help.

Discussions have also highlighted the separation between product security and infrastructure security. While infrastructure security in crypto is similar to other industries, the product-specific challenges are unique to the space. Increasing the number of qualified experts will require budgeting for educational initiatives. BGIN can play a role in creating educational content to help people better understand cybersecurity in crypto.

For responsible disclosure practices to work in the crypto industry, we need to identify what is missing in current practices. Although bug bounty programs are common and help reduce vulnerabilities, they are not a comprehensive solution. A robust cybersecurity framework must combine various approaches, such as certification programs and vulnerability testing.

The crypto industry also lacks a specific data format for threat intelligence and vulnerability information. Developing a taxonomy of threat intelligence is a necessary first step toward creating standardized formats for this information. However, some believe that the crypto and blockchain industry has not matured enough to identify specific items to be shared and exchanged.

Although the CCSS standard exists, there is skepticism about its effectiveness and adaptability to new developments in the industry. While CCSS is one of the few Web3 security standards, it may not fully reflect current attack vectors or meet the industry's evolving needs. BGIN could aim to create standards and best practices for blockchain governance to address these gaps.

Defining a taxonomy of threat intelligence and then developing data formats for this information could help the crypto industry establish better alignment with broader cybersecurity frameworks. In the long term, creating comprehensive standards for threat intelligence and vulnerability data will be critical.

CCSS is not static; a new version, 8.2, will be released soon. The CCSS steering committee has been working to bring the standard online and make it reflective of current attack vectors. The committee has also launched an auditors program with around 20 certified CCSS auditors worldwide and several active audits.The new version will be released in a month or two. The new version has 30% more requirements than the current version. These include risk governance, service provider management, wallet monitoring requirements, and support for single signature mechanisms. There are also enhancements to existing requirements. It went through a substantial stakeholder feedback process where anyone in the world could submit their suggestions for improving CCSS. There is no need for membership or committee participation to make suggestions. The stakeholder feedback process conducted a couple of months ago received significant community input, resulting in over 30% more requirements being added to the standard. Now, CCSS is a well-rounded standard.

Thank you for the update on CCSS.

I’m not very familiar with CCSS, but I have a question about what it covers specifically. When it comes to creating standards within BGIN, what are the missing pieces in terms of standardization? We’re not looking to create the same standards for the same problems. I’d like a better understanding of what CCSS covers and what roles BGIN can play.

CCSS is not a baseline information security standard like ISO 27001, which covers patch management, configuration management, and user access management. Instead, CCSS focuses on key management requirements, adding enhancements to address the unique

properties of blockchain and DLT systems. For example, wallet monitoring is included in CCSS but not in ISO 27001. It has been considered a bolt-on to ISO 27001.

However, feedback from stakeholders indicated that many organizations are deciding between ISO 27001 and CCSS because they feel CCSS aligns more closely with their architectural and design patterns. Based on this, baseline information security controls like service provider management and risk governance have been introduced in CCSS. For example, an executive member must acknowledge the risks associated with their organization's information security.

Version 8.2 also introduces smart contract audits to address issues like version discrepancies. Often, an initial version of a smart contract is audited, but subsequent versions with additional functionality may not undergo an audit, leading to potential vulnerabilities. CCSS now requires audits for every version of a smart contract.

This makes CCSS distinct from baseline standards like ISO 27001. While it started as a bolt-on to ISO, it has evolved to include controls that strengthen it as an independent standard, addressing major attack vectors.

Thank you for answering my question.

To clarify, CCSS started with key management, focusing on Layer 1 blockchain technology, such as custody and cryptocurrency exchanges. However, with the emergence of Layer 2 protocols and cryptographic advancements like zero-knowledge proofs, key management has become more complex. The number of keys and their lifecycle differs significantly from traditional PKI systems. What is CCSS's future direction for handling this complexity?

Before working on Version 8.2, there were concerns that CCSS was still aligned with Bitcoin's general concepts. For example, it referenced private keys without accounting for protocols like MPC. In Version 8.2, we replaced mentions of private keys with broader terms like key material and multi-signature mechanisms, making the standard more adaptable to future technologies.

CCSS is a community-driven standard, and we encourage contributions from around the world to ensure it reflects emerging technologies. The steering committee actively incorporates feedback to keep CCSS updated and relevant.

Thank you. This aligns with our goal of leveraging existing standards like CCSS for new technologies in blockchain. BGIN could play a crucial role in advancing discussions around new technologies and supporting future revisions of standards like CCSS.

That's exactly why I was invited to discussions at the TC307 plenary in Sydney. Collaboration with other organizations and nonprofits is essential to improve security in this space. The CCSS steering committee is open to partnerships to enhance security comprehensively.

I'm not a cybersecurity expert, but I've heard of other standard-setting bodies like the Blockchain Security Standards Council. Are there other organizations we should pay attention

to? BGIN's goal isn't to compete but to fill gaps in the industry. Are there others creating standards similar to CCSS?

There is the Blockchain Security Standards Council, a membership-only organization. They aim to introduce security standards for Web3 and may release standards by the end of this year. Unlike CCSS, the Blockchain Security Standards Council requires membership fees. CCSS is completely volunteer-driven, accepting contributions from anyone without restrictions.

TC307 under ISO is also working on blockchain and DLT standards. However, I'm not aware of any cryptocurrency-specific standards being introduced under ISO. Most efforts currently focus on broader blockchain and DLT standards.

In my opinion, initiatives like Crypto ISAC could be valuable, but the larger issue is the lack of qualified security experts in the crypto space. Even with existing information-sharing frameworks, the limited number of experts poses a challenge. BGIN could focus on creating educational materials to help smaller startups that lack resources for dedicated security teams.

Additionally, there's a need to increase awareness among leadership about the liabilities and risks within their ecosystems. This could pressure organizations to invest in qualified security professionals. Education and tools tailored to Solidity and Rust, the two dominant languages in the space, would also be impactful.

Finally, formal verification of Rust contracts could significantly enhance security. Developing automated benchmarking tools for smart contracts could lower entry barriers and reduce reliance on costly audits, making the ecosystem more accessible and secure. Such tools could also attract funding from large treasuries, as they'd offer a cost-effective alternative to hiring security experts. Addressing the high cost of audits is critical for Web3's growth.

So you mentioned the different languages you know like each protocol niche like you know blockchain you know use right. And I'm not really sure like if crypto is like he's thinking about this because like, you know, they're just talking about, you know, blockchain as a whole. I think we should start from like talking about what are the main languages we should deal with. I think, yeah, this is a great discussion point, I think. Thank you. Thank you very much for it.

Yeah. Based on the comments he made, does any remote participants have any opinion about this?

Oh, sorry. I was just thinking, I was actually doing a presentation to a country's regulators this morning on the importance of standards when they're doing their policymaking and the regulations around introducing RESPs into their country. And one of the key things I was thinking of as the gentleman before was speaking about, you know, where do we put all this type of information. And then I reflected back on the factors that another point was made is that there's no big stick in this sector yet. For example, as mentioned before with PCI DSS and the credit card security standard, there's a very big stick there, and that's called the card schemes. It's the Visa and the MasterCards that actually created the standard. If an entity is not PCI DSS compliant, then there's a very good chance they could be fined or have their credit card

merchant services taken away from them, meaning they can't accept credit cards from their customers.

And that's an extremely powerful big stick that they have. And then I was reflecting back on the meeting I had this morning with the regulators and it seems that there's almost a possibility that we could introduce a big stick by way of regulations. I believe a lot of jurisdictions out there are attempting to implement requirements around information security controls for VEFs when they come in to be licensed. Some of them are quite vague, some of them appear to be missing key controls. So I was just wondering if we could work with the regulators and the policymakers around the world to actually educate them on the importance of having information security control regulations for the vast. And as one of those controls would be some type of vulnerability management.

And from there, something in the industry could be, this could be a tipping point for the factors now we need to look at vulnerability management in order to get a license to operate in a jurisdiction. And, you know, somehow this big stick forces vulnerability management to come up to a head where there's more discussion in the marketplace about how do we tackle vulnerability management. Thank you.

Thank you. We still have time left, so I don't know if we could also give a brief introduction. Will be like wallet security thing you discussed recently. I don't have any materials to display today, but regarding the cybersecurity, this is just, you know, that incident handling or vulnerability handling or something like that. But the other aspect is how we satisfy the level of security of the product. Especially for those who are it, but so we have different types of, you know, software called the product. How do we have software code a product, something like that?

So I'm an expert on the cryptography. And so in other industries than blockchain, we already have the standards for proving or certifying the quality of protocol specification or implementation of the security for the implementation. So we already have the ISO standards, the 27,000 series. So as Mark mentioned before, it's a so-called common criteria. So this is a gorgeous international standard. Of course, the process to have certification of the product aligning the ISO 27000 series is very heavy for small startups. It's not too easy for most startups to align that ISM standard or common criteria standard.

Especially for the crypto industry, some companies say that they want to align the ISO standard or, you know, NIST standard, like a 140-3. But it takes a few years, three or four or five years to have certification from NIST. So if you Google the list of certified products for the 123, you'll see how they are listed. Of course, some companies say they are 140-3 compliant but don't care about the extra certification process by third parties. So we already have existing standards for keeping the level of security for software and hardware.

And I'm not sure that it's feasible for smaller startups, but we need to reconsider how we compromise on that standard if the process is too heavy for the crypto industry. We may need to create a modified version of it to make the alignment to the standard easier for small startups. As an initial step, we should create some specifications or security targets, like a protection

profile. But there is no protection profile or security target document in the cryptocurrency world. This is a good puzzle step to start with.

Anyway, that is my observation. But let's start with learning the current international standard for the security implementation of software and hardware and creating a modified version for the crypto industry.

Mark here again. I understand exactly what you're saying. ISO 27001 certification is quite heavy for startups, especially with limited resources. CCSS has three levels of certification. Level one is for startups, focusing on controls that greatly reduce the risk of breaches from common attack vectors. Level two adds more controls for larger entities, and level three applies the full set of CCSS requirements for large enterprises.

In terms of standards for smart contracts, we've released only three requirements in the latest version, but we're open to collaboration and input from the community. We also hope to promote CCSS to regulators, associations, and communities worldwide to build awareness and adoption.